



Vulnerability Scanning Report

2025-05-21

Automated vulnerability scans are conducted quarterly as part of the "Cyber Companion" subscription. These scans aim to identify potential security vulnerabilities in monitored assets.

The remediation of identified vulnerabilities remains the exclusive responsibility of the client.

Following industry best practices, the recommended remediation timelines are:

Severity Level	Recommended Timeframe
High/Critical	Within 1 month
Medium	Within 3 months
Low	Between 6–12 months

Clients may request assistance from the CyberAssist team for:

- Scan report interpretation
- Guidance on implementing fixes
- Technical or operational constraint arbitration

Advanced security audit services are available upon request, including:

- Penetration testing (black box, grey box, white box)
- Architecture audits
- Configuration audits
- Code reviews

These audits are customized and may be subject to a tailored quote. Please contact us for more information.

As part of our continuous improvement process, clients are encouraged to report:

- Any identified false positives
- Any specific constraints to be considered for future scans

Assessment Scope Details

Item	Details
Project Title	[Name of the Security Assessment]
Client Name	[Company Name]
Client Point of Contact	[Full Name, Role]
Assessment Type	[e.g., Web Application Pentest, Architecture Review, Configuration Audit]
Target Scope	[Website URL(s), IP Range, Application Name, etc.]
Environment	[Production / Pre-production / Development]
Assessment Conducted by	Evolvity Partners with Giantlink
Assessment Start Date	2025-05-21
Assessment End Date	2025-05-21
Report Delivery Date	[DD/MM/YYYY]
Methodology Used	[e.g., OWASP Testing Guide, OSSTMM, NIST SP800-115, Custom Framework]
Access Mode	[Black Box / Grey Box / White Box]
Authentication Used	[None / Test credentials / Admin access]

Scan Methodology Overview

Detailed Step Descriptions

Spidering

The scanner initiates a discovery phase where it recursively explores all accessible endpoints by parsing HTML content, JavaScript, forms, and other user interface elements. This step ensures broad surface coverage of the application.

Passive Analysis

While crawling, the tool passively monitors all HTTP/S requests and responses. It looks for signs of misconfigurations, information disclosure, or insecure HTTP headers without interacting with the application in a disruptive way.

Active Scanning

Based on the endpoints discovered during the crawl, the tool actively probes for known vulnerabilities such as injection flaws (e.g., SQLi, XSS), authentication and session management weaknesses, access control issues, and insecure deserialization. The tool mimics attacker techniques while preserving the integrity of the target system.

Risk Analysis

Each identified issue is evaluated using a risk matrix that considers both technical severity and potential business impact. The tool assigns severity levels according to standard CVSS scoring.

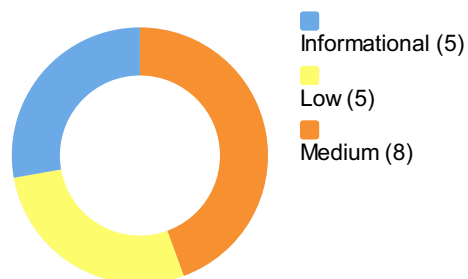
Report

A detailed report is generated, documenting each finding with evidence (e.g., request/response pairs), risk descriptions, and suggested remediation steps. The methodology ensures that results are reproducible and traceable.

Summary of sequences

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	3
CSP: Failure to Define Directive with No Fallback	Medium	2
CSP: Wildcard Directive	Medium	2
CSP: script-src unsafe-inline	Medium	2
CSP: style-src unsafe-inline	Medium	2
Missing Anti-clickjacking Header	Medium	3
Sub Resource Integrity Attribute Missing	Medium	6
Vulnerable JS Library	Medium	2
Insufficient Site Isolation Against Spectre Vulnerability	Low	12
Permissions Policy Header Not Set	Low	11
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	4
Strict-Transport-Security Header Not Set	Low	11
X-Content-Type-Options Header Missing	Low	11
Information Disclosure - Suspicious Comments	Informational	2
Modern Web Application	Informational	3
Re-examine Cache-control Directives	Informational	5
Retrieved from Cache	Informational	12
Storable and Cacheable Content	Informational	11

Risk levels percentage



CWE Total occurrences

CWE Total occurrences: 16 occurrences in total.



Note: The blue color in the bars does not represent risk severity. CWEs may vary in impact depending on context. Always check the "Alerts detected" table for risk levels per occurrence.

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	8
Low	5
Informational	5
False Positives	0

Disclaimer: Findings are automatically generated and may not cover business logic flaws, authentication workflows, or other context-dependent vulnerabilities. Manual review is recommended.

Alerts detected (18)

ID	M1
Name	Absence of Anti-CSRF Tokens
Risk	Medium

Description	No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.
Instances (3)	• GET https://www.evolvitypartners.com/ • Evidence: <code><form action="/form-handler.php" method="post"></code> • Other: No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "checkbox" "email" "fname" "fonction" "lname" "offer" "organization" "phone" "submit"]. • GET https://www.evolvitypartners.com/index.php • Evidence: <code><form action="/form-handler.php" method="post"></code> • Other: No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "checkbox" "email" "fname" "fonction" "lname" "offer" "organization" "phone" "submit"]. • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: <code><form action="/form-handler.php" method="post"></code> • Other: No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "checkbox" "email" "fname" "fonction" "lname" "offer" "organization" "phone" "submit"].

CONFIDENTIAL

Recommendation	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html
CWE Id	352
WASC Id	9
Plugin Id	10202
ID	M2
Name	CSP: Failure to Define Directive with No Fallback
Risk	Medium
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.

CONFIDENTIAL

Instances (2)	• GET https://www.evolvitypartners.com/ • Evidence: <code>upgrade-insecure-requests</code> • Other: The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src. • GET https://www.evolvitypartners.com/index.php • Evidence: <code>upgrade-insecure-requests</code> • Other: The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Recommendation	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

ID	M3
Name	CSP: Wildcard Directive
Risk	Medium
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

CONFIDENTIAL

Instances (2)	• GET https://www.evolvitypartners.com/ • Evidence: <code>upgrade-insecure-requests</code> • Other: The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src • GET https://www.evolvitypartners.com/index.php • Evidence: <code>upgrade-insecure-requests</code> • Other: The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src
Recommendation	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055
ID	M4
Name	CSP: script-src unsafe-inline
Risk	Medium
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

CONFIDENTIAL

Instances (2)	• GET https://www.evolvitypartners.com/ • Evidence: upgrade-insecure-requests • Other: script-src includes unsafe-inline. • GET https://www.evolvitypartners.com/index.php • Evidence: upgrade-insecure-requests • Other: script-src includes unsafe-inline.
Recommendation	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

ID	M5
Name	CSP: style-src unsafe-inline
Risk	Medium
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Instances (2)	• GET https://www.evolvitypartners.com/ • Evidence: upgrade-insecure-requests • Other: style-src includes unsafe-inline. • GET https://www.evolvitypartners.com/index.php • Evidence: upgrade-insecure-requests • Other: style-src includes unsafe-inline.
Recommendation	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.

CONFIDENTIAL

Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

ID	M6
Name	Missing Anti-clickjacking Header
Risk	Medium
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Instances (3)	• GET https://www.evolvitypartners.com/ • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: N/A • Other: N/A
Recommendation	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

ID	M7
Name	Sub Resource Integrity Attribute Missing

CONFIDENTIAL

Risk	Medium
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
Instances (6)	• GET https://www.evolvitypartners.com/ • Evidence: <code><link href='https://fonts.googleapis.com/css?family=Source+Sans+Pro:400,300,700' rel='stylesheet' type='text/css'></code> • Other: N/A • GET https://www.evolvitypartners.com/ • Evidence: <code><link href='https://fonts.googleapis.com/css?family=Unica+One' rel='stylesheet' type='text/css'></code> • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: <code><link href='https://fonts.googleapis.com/css?family=Source+Sans+Pro:400,300,700' rel='stylesheet' type='text/css'></code> • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: <code><link href='https://fonts.googleapis.com/css?family=Unica+One' rel='stylesheet' type='text/css'></code> • Other: N/A • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: <code><link href='https://fonts.googleapis.com/css?family=Source+Sans+Pro:400,300,700' rel='stylesheet' type='text/css'></code> • Other: N/A • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: <code><link href='https://fonts.googleapis.com/css?family=Unica+One' rel='stylesheet' type='text/css'></code> • Other: N/A
Recommendation	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003
ID	M8
Name	Vulnerable JS Library
Risk	Medium

CONFIDENTIAL

Description	The identified library appears to be vulnerable.
Instances (2)	• GET https://www.evolvitypartners.com/js/bootstrap.min.js • Evidence: * <code>Bootstrap v3.3.6</code> • Other: The identified library bootstrap, version 3.3.6 is vulnerable. CVE-2018-14041 CVE-2019-8331 CVE-2018-20677 CVE-2018-20676 CVE-2018-14042 CVE-2016-10735 CVE-2024-6484 CVE-2024-6485 https://nvd.nist.gov/vuln/detail/CVE-2024-6485 https://nvd.nist.gov/vuln/detail/CVE-2024-6484 https://github.com/advisories/GHSA-pj7m-g53m-7638 https://github.com/advisories/GHSA-vxmc-5x29-h64v https://github.com/rubysec/ruby-advisory-db/blob/master/gems/bootstrap-sass/CVE-2024-6484.yml https://github.com/twbs/bootstrap/issues/20631 https://github.com/advisories/GHSA-9mvj-f7w8-pvh2 https://github.com/advisories/GHSA-9v3m-8fp8-mj99 https://github.com/twbs/bootstrap/issues/28236 https://www.herodevs.com/vulnerability-directory/cve-2024-6485 https://github.com/twbs/bootstrap/issues/20184 https://www.herodevs.com/vulnerability-directory/cve-2024-6484 https://github.com/advisories/GHSA-ph58-4vrj-w6hr https://github.com/twbs/bootstrap https://github.com/advisories/GHSA-4p24-vmcr-4gqj https://github.com/rubysec/ruby-advisory-db/blob/master/gems/bootstrap/CVE-2024-6484.yml https://nvd.nist.gov/vuln/detail/CVE-2018-20676 • GET https://www.evolvitypartners.com/js/jquery.js • Evidence: <code>/*! jQuery v1.11.1</code> • Other: The identified library jquery, version 1.11.1 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2015-9251 CVE-2019-11358 https://github.com/jquery/jquery/issues/2432 http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/ http://research.insecurelabs.org/jquery/test/ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/advisories/GHSA-rmxg-73gg-4p98 https://nvd.nist.gov/vuln/detail/CVE-2015-9251 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://bugs.jquery.com/ticket/11974 https://github.com/jquery/jquery.com/issues/162 https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Recommendation	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	-1
Plugin Id	10003
ID	L1
Name	Insufficient Site Isolation Against Spectre Vulnerability

Risk	Low
Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.

Instances (12)

- GET <https://www.evolvitypartners.com/>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/css/bootstrap.min.css>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/css/font-awesome.min.css>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/css/magnific-popup.css>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/css/owl.carousel.css>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/css/owl.theme.css>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/robots.txt>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/sitemap.xml>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/sitemap.xml>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/>
- Evidence: N/A
- Other: N/A
- GET <https://www.evolvitypartners.com/sitemap.xml>
- Evidence: N/A
- Other: N/A

CONFIDENTIAL

Recommendation	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Cross-Origin_Resource_Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

ID	L2
Name	Permissions Policy Header Not Set
Risk	Low
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.

Instances (11)	• GET https://www.evolvitypartners.com/ • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/bootstrap.min.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/custom.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/jquery.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/jquery.magnific-popup.min.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/magnific-popup-options.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/owl.carousel.min.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/smoothscroll.js • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/js/wow.min.js • Evidence: N/A • Other: N/A
Recommendation	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.

CONFIDENTIAL

Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

ID	L3
Name	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Risk	Low
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
Instances (4)	• GET https://www.evolvitypartners.com/ • Evidence: x-powered-by: PHP/8.2.28 • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: x-powered-by: PHP/8.2.28 • Other: N/A • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: x-powered-by: PHP/8.2.28 • Other: N/A • POST https://www.evolvitypartners.com/form-handler.php • Evidence: x-powered-by: PHP/8.2.28 • Other: N/A
Recommendation	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html
CWE Id	497
WASC Id	13
Plugin Id	10037

CONFIDENTIAL

ID	L4
Name	Strict-Transport-Security Header Not Set
Risk	Low
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.

Instances (11)	• GET https://www.evolvitypartners.com/ • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/animate.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/bootstrap.min.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/font-awesome.min.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/magnific-popup.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/owl.carousel.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/owl.theme.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/css/style.css • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/robots.txt • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/sitemap.xml • Evidence: N/A • Other: N/A
Recommendation	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.

Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

ID	L5
Name	X-Content-Type-Options Header Missing
Risk	Low
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Instances (11)	• GET https://www.evolvitypartners.com/ • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/animate.css • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/bootstrap.min.css • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/font-awesome.min.css • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/magnific-popup.css

	• Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/owl.carousel.css • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/owl.theme.css • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/css/style.css • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/index.php • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/robots.txt • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. • GET https://www.evolvitypartners.com/sitemap.xml • Evidence: N/A • Other: This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Recommendation	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

CONFIDENTIAL

Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

ID	I1
Name	Information Disclosure - Suspicious Comments
Risk	Informational
Description	The response appears to contain suspicious comments which may help an attacker.
Instances (2)	• GET https://www.evolvitypartners.com/js/jquery.js • Evidence: <code>username</code> • Other: The following pattern was used: <code>\bUSERNAME\b</code> and was detected in likely comment: <code>"//,Gc=/^([w.+~]+:)(?:\\V(?:[^\V?#]*@)([^\V?#]*)((?:\d+)))/,Hc={},lc={},Jc="*/".concat("*/");try{zc=location.href}catch(Kc)", see evidence field for the suspicious comment/snippet.</code> • GET https://www.evolvitypartners.com/js/magnific-popup-options.js • Evidence: <code>from</code> • Other: The following pattern was used: <code>\bFROM\b</code> and was detected in likely comment: <code>"// The "opener" function should return the element from which popup will be zoomed in", see evidence field for the suspicious comment/snippet.</code>
Recommendation	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

ID	I2
Name	Modern Web Application
Risk	Informational
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.

CONFIDENTIAL

Instances (3)	• GET https://www.evolvitypartners.com/ • Evidence: <code>Contact</code> • Other: Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application. • GET https://www.evolvitypartners.com/index.php • Evidence: <code>Contact</code> • Other: Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application. • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: <code>Contact</code> • Other: Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
Recommendation	This is an informational alert and so no changes are required.
Reference	
CWE Id	-1
WASC Id	-1
Plugin Id	10109

ID	I3
Name	Re-examine Cache-control Directives
Risk	Informational
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.

Instances (5)	• GET https://www.evolvitypartners.com/ • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/index.php?stat=2 • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/robots.txt • Evidence: N/A • Other: N/A • GET https://www.evolvitypartners.com/sitemap.xml • Evidence: N/A • Other: N/A
Recommendation	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015
ID	I4
Name	Retrieved from Cache
Risk	Informational
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
Instances (12)	• GET https://www.evolvitypartners.com/css/bootstrap.min.css • Evidence: Age: 946

- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/css/font-awesome.min.css>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/css/style.css>
- **Evidence:** Age: 947
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/images/Confonlystart.png>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/images/Conformit%C3%A9.png>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/images/Innovation.png>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/images/Risque.png>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/images/team-img1.jpg>
- **Evidence:** Age: 947
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/js/jquery.js>
- **Evidence:** Age: 947
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/js/jquery.magnific-popup.min.js>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/js/smoothscroll.js>
- **Evidence:** Age: 946
- **Other:** The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
- **GET** <https://www.evolvitypartners.com/js/wow.min.js>
- **Evidence:** Age: 946

CONFIDENTIAL

	• Other: The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Recommendation	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://tools.ietf.org/html/rfc7234 https://tools.ietf.org/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	-1
WASC Id	-1
Plugin Id	10050
ID	I5
Name	Storable and Cacheable Content
Risk	Informational
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

Instances (11)

- **GET** <https://www.evolvitypartners.com/>
- **Evidence:** N/A
- **Other:** In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
- **GET** <https://www.evolvitypartners.com/css/animate.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/css/bootstrap.min.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/css/font-awesome.min.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/css/magnific-popup.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/css/owl.carousel.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/css/owl.theme.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/css/style.css>
- **Evidence:** max-age=604800
- **Other:** N/A
- **GET** <https://www.evolvitypartners.com/index.php>
- **Evidence:** N/A
- **Other:** In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
- **GET** <https://www.evolvitypartners.com/robots.txt>
- **Evidence:** N/A
- **Other:** In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
- **GET** <https://www.evolvitypartners.com/sitemap.xml>
- **Evidence:** N/A
- **Other:** In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.

CONFIDENTIAL

Recommendation	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049